

SOP-SA-03 — Auth & Authorization

Kode	SOP-SA-03
Pemilik	Saitama (Senior Backend Engineer)
Revisi	1.0 · Berlaku 2026-05-29 · Reviu per kuartal
Referensi	OWASP ASVS, OWASP Top 10, ISO/IEC 27001 (Annex A access control), tools/auth-authorization-checklist.md
COBIT	DSS05 (Managed Security Services)

1. Tujuan

Menjamin tiap endpoint sensitif punya **otentikasi (authn — siapa kamu) + otorisasi (authz — boleh apa kamu)** yang benar, pakai library proven (no roll-your-own crypto), supaya gak ada endpoint bocor tanpa proteksi.

2. Ruang Lingkup

- **Berlaku:** semua endpoint yang akses/ubah data milik user, data sensitif (money/saldo/PII), atau aksi privileged.
- **Tidak berlaku:** endpoint publik by-design (health check, landing data publik) — tetap dicatat alasan publiknya.

3. Definisi & Istilah

- **Authn (Authentication)** — verifikasi identitas (login, token valid).
- **Authz (Authorization)** — verifikasi izin (role/scope check).
- **RBAC** — Role-Based Access Control; **Scope** — izin granular (cth `payment:write`).
- **Roll-your-own crypto** — bikin algoritma/crypto sendiri = anti-pattern (insecure).

4. Referensi

OWASP ASVS (verification standard), OWASP Top 10 (Broken Auth & Broken Access Control), ISO/IEC 27001 Annex A (kontrol akses), Tata mandate (PO money/saldo isolasi STRICT).

5. Tanggung Jawab (RACI)

Aktivitas	R	A	C	I
Pilih auth model	Saitama	Saitama	@kakashi (security tradeoff)	tim
Implementasi authn+authz	Saitama	Saitama	—	@killua, @I
Trade-off security (Type-1)	Saitama	Tata (via @kakashi)	@kakashi	tim

6. Prosedur

6.1 Pilih model

- 6.1.1 Tentukan **auth choice** (PLAYBOOK §5): web (cookie OK) → session httpOnly; API-only → JWT + refresh; 3rd party → OAuth 2.0 + scopes.
- 6.1.2 **Decision point**: ini trade-off security baru (simpan PII, pilih crypto, model auth baru)? → **Type-1, escalate via @kakashi** 🚫. Pakai existing model → lanjut.
- 6.1.3 **Selalu library proven** (Lucia, Better Auth, Passport). **Exit kalau tergoda custom crypto → STOP, pakai library.**

6.2 Implementasi authn

- 6.2.1 Validasi token/session di **boundary** (middleware), sebelum business logic.
- 6.2.2 **Rate limit** endpoint login/signup/send-email (anti brute-force, kontrol SA-C2/SA-C3).
- 6.2.3 **Secret di env** (12-Factor), never di kode (anti OWASP Cryptographic Failures).

6.3 Implementasi authz

- 6.3.1 **Role/scope check** di tiap endpoint sensitif — default deny, allow eksplisit.
- 6.3.2 **Isolasi data per-user** — user A gak bisa akses data user B (cek ownership, bukan cuma role).
- 6.3.3 **Money/saldo isolasi STRICT** (Tata mandate) — aksi finansial butuh authz ketat + audit (SOP-SA-04).
- 6.3.4 Jalankan auth-authorization-checklist.

6.4 Verifikasi

- 6.4.1 **Test akses negatif**: tanpa token → 401 ; token valid tapi role/owner salah → 403 . **Exit criteria**: test negatif pass.
- 6.4.2 **Decision point**: semua endpoint sensitif ke-cover authn+authz? → lanjut handoff. Ada yang bolong → fix dulu (kontrol SA-C3 = 100%).

7. Pengecualian

- **Endpoint publik by-design**: dicatat alasan + dipastikan gak expose data sensitif.
- **Internal service-to-service**: mutual TLS / signed JWT, bukan user auth.

8. Rekaman & Retensi

Rekaman	Lokasi	Retensi
Auth model + alasan	doc / log.md	Permanen
Test auth negatif (evidence)	log.md	Permanen
ADR trade-off security (Type-1)	adr/NNN-*.md	Permanen

9. Indikator Kinerja (KPI)

KPI	Rumus	Target
Auth coverage	# endpoint sensitif ber-authn+authz ÷ total sensitif	100% (SA-C3)
Broken access control	# endpoint user A bisa akses data user B	0
Custom crypto	# implementasi auth/crypto buatan sendiri	0

10. Riwayat Revisi

Rev	Tanggal	Perubahan
1.0	2026-05-29	Terbit pertama